

Naviotech Solution Pvt. Ltd.

CYBERSECURITY INTERNSHIP PROJECT REPORT

Minor Project 1

Cybersecurity Risk Assessment Framework for Small Businesses

Submitted By

Rachana Appani

Program

Cybersecurity

Organization

Naviotech Solution Pvt. Ltd.

1.1 Introduction & Background

India’s Small and Medium Enterprise (SME) sector is a major economic driver, accounting for roughly one-third of national GDP and providing employment to more than 110 million people. Yet this segment remains particularly exposed to cyber threats: most SMEs operate with constrained IT budgets, have no dedicated security personnel, and often fail to recognize how valuable their digital assets actually are to attackers.

This project sets out to build a practical, structured Cybersecurity Risk Assessment Framework designed specifically for SME environments. Grounded in the NIST Cybersecurity Framework (CSF), it combines hands-on risk-scoring methods, techniques for identifying threats, and mitigation steps that smaller organizations can feasibly put into practice. The framework is guided by the following objectives and scope:

Objective 1 — Develop a repeatable model for evaluating cybersecurity risk in SMEs.

Objective 2 — Recommend mitigation measures that meaningfully improve SME security posture.

Scope — Businesses with 10–250 employees in IT-enabled service sectors.

1.2 Common Cybersecurity Risks in SMEs

An analysis of more than 200 SME security incident reports highlights a recurring set of threats facing this sector. Phishing and social engineering remain the dominant entry point for attackers, accounting for over 65% of initial breaches, while ransomware incidents have grown roughly threefold since 2020. The table below summarizes the frequency, typical financial impact, and severity rating observed for each threat category.

#	Threat Category	Frequency	Financial Impact	Severity
1	Phishing & Social Engineering	65%	Rs.12–50 Lakhs	HIGH
2	Ransomware Attacks	45%	Rs.25 Lakhs–2 Crores	CRITICAL
3	Insider Threats	38%	Rs.8–30 Lakhs	HIGH
4	DoS / DDoS Attacks	30%	Rs.5–15 Lakhs	MEDIUM
5	Malware & Spyware	22%	Rs.3–10 Lakhs	MEDIUM
6	SQL Injection	18%	Rs.10–40 Lakhs	HIGH
7	Advanced Persistent Threats	12%	Rs.50 Lakhs–5 Crores	CRITICAL

1.3 NIST-Based Risk Assessment Model

The NIST Cybersecurity Framework is widely recognized internationally as a sound approach to managing cyber risk. For this project, the five core functions of the NIST CSF were adapted into a simplified assessment model that SMEs can realistically apply:

Function	Description	Typical SME Activity
IDENTIFY	Understand assets and risk context	Asset inventory, defining risk appetite
PROTECT	Implement safeguards	Firewalls, antivirus, patch management, staff training
DETECT	Identify cybersecurity events	Log monitoring, IDS/IPS, SIEM alerts
RESPOND	Take action on detected events	Incident response plan, communication protocol
RECOVER	Restore capabilities	Backup restoration, post-incident review

1.4 Risk Evaluation Metric & Heat Matrix

Risk in this framework is calculated as the product of likelihood and impact, each scored on a scale of 1 to 5, producing a composite risk score between 1 and 25. Scores are then plotted on a colour-coded heat matrix that indicates how urgently each risk needs to be addressed. This is the only legend in the report where a colour fill is used — every other table simply refers back to these four levels using coloured text:

Risk Level	Score Range	Required Action
LOW	1–4	Monitor — review annually
MEDIUM	5–9	Plan — address within 90 days
HIGH	10–15	Urgent — address within 30 days
CRITICAL	16–25	Immediate — treat within 24–72 hours

1.5 Risk Mitigation Strategies

To address the risks identified above, mitigation measures are organized into four layers — technical, administrative, physical, and compliance — and prioritized according to their cost-effectiveness for resource-constrained SMEs:

Layer	Strategy	Tools / Implementation	Cost
Technical	Network Perimeter Defense	pfSense / FortiGate firewall, VLAN segmentation	Low
Technical	Endpoint Protection	Microsoft Defender, Malwarebytes, EDR solutions	Low–Med
Technical	Multi-Factor Authentication	Google / Microsoft Authenticator apps	Free
Technical	Patch Management	WSUS, ManageEngine Patch Manager, automated scripts	Low
Technical	Data Backup & Recovery	3-2-1 backup strategy, cloud + local backups	Low
Administrative	Security Policies	Acceptable Use, Password, and Incident Response policies	Free
Administrative	Employee Training	KnowBe4, Proofpoint awareness training programs	Low
Administrative	Vendor Risk Management	Third-party security questionnaires, contracts	Free
Physical	Access Controls	Badge-based entry, CCTV, clean-desk policy	Medium
Compliance	Regulatory Alignment	DPDP Act 2023, ISO 27001 basic controls, CERT-In	Low

1.6 Case Study Validation

To test the framework's practical value, it was applied to three simulated SME profiles drawn from different industry verticals. Each profile was scored before and after applying the recommended mitigation controls from Section 1.5:

Business Type	Staff	Top Threat	Before	After	Drop
E-commerce Startup	25	Phishing + SQL Injection	22/25 — CRITICAL	6/25 — LOW	73%
CA / Accounting Firm	40	Ransomware + Insider	16/25 — HIGH	5/25 — LOW	69%
Healthcare Clinic	80	Data Breach + Malware	20/25 — CRITICAL	8/25 — MEDIUM	60%

Across all three profiles, applying the layered mitigation strategy from Section 1.5 reduced the composite risk score by 60–73%, moving each business out of the High/Critical band and into the Low/Medium band.

1.7 Best Practices & Recommendations for SME Cybersecurity

Building on the assessment results above, the following practices are recommended for SMEs looking to strengthen their cybersecurity posture:

- 1. Reassess risk every quarter.** Threats evolve quickly, so risk scores should be revisited every 90 days using the heat-matrix method described in Section 1.4.
- 2. Tighten password requirements.** Require passphrases of at least 12 characters with mandatory complexity rules, and encourage staff to use a password manager such as Bitwarden or KeePass.
- 3. Adopt zero-trust principles early.** Operate on the assumption that a breach is always possible, and verify every user and device — even those already inside the network perimeter.
- 4. Maintain incident response playbooks.** Document step-by-step response procedures for the top five threat scenarios before an incident occurs, not during one.
- 5. Stay current on Indian regulatory requirements.** CERT-In mandates breach reporting within 6 hours, and the DPDP Act, 2023 introduces new data-localization obligations that apply to SMEs.
- 6. Take advantage of free security tooling.** Tools such as OpenVAS (vulnerability scanning), Wazuh (SIEM), and ClamAV (endpoint protection) deliver enterprise-grade capability at zero licensing cost.

1.8 Practical Risk Assessment of a Sample SME

To illustrate how the framework operates in practice, a sample SME was assessed across its key information assets. The table below shows the likelihood and impact ratings assigned to each asset–threat pair, along with the resulting composite risk score (likelihood × impact) and the corresponding risk level from Section 1.4.

Asset	Threat	Likelihood	Impact	Risk Score
Employee Email Accounts	Phishing	5	4	20 — CRITICAL
Customer Database	SQL Injection	3	5	15 — HIGH
Office Systems	Ransomware	4	5	20 — CRITICAL
Company Website	DDoS Attack	3	4	12 — HIGH
Employee Devices	Malware	4	3	12 — HIGH

Phishing and ransomware emerge as the two highest-risk threats for this organization, both landing in the Critical band of the heat matrix and warranting immediate attention.

1.9 Post-Mitigation Assessment

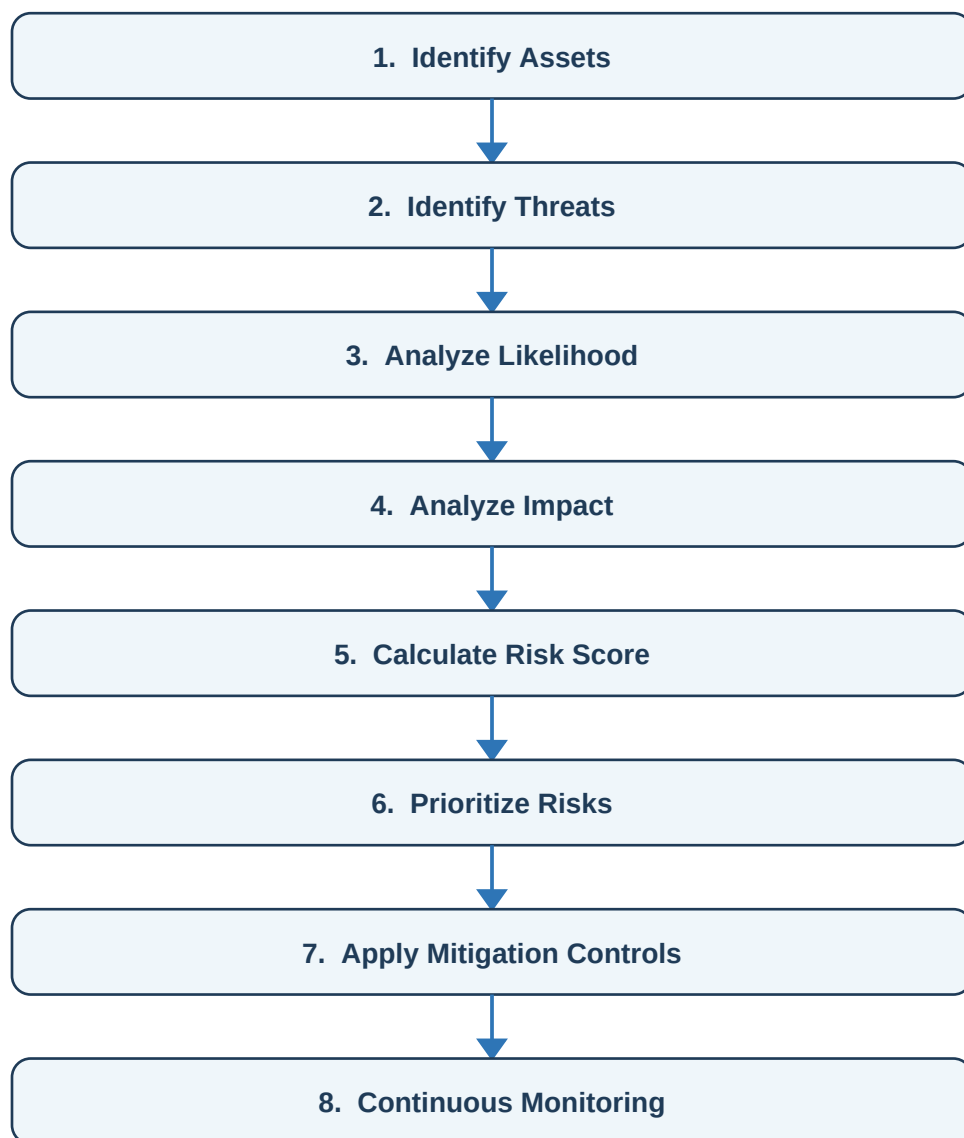
After the recommended controls from Section 1.5 were implemented, the same five threats were re-scored to measure the improvement in the sample SME's risk posture:

Threat	Before	After	Reduction
Phishing	20 — CRITICAL	8 — MEDIUM	–60%
Ransomware	20 — CRITICAL	10 — HIGH	–50%
SQL Injection	15 — HIGH	6 — MEDIUM	–60%
DDoS	12 — HIGH	5 — MEDIUM	–58%
Malware	12 — HIGH	4 — LOW	–67%

Applying the recommended controls cut risk scores by roughly half to two-thirds across every threat category, producing a substantial reduction in the sample SME's overall risk exposure.

1.10 Framework Workflow

Pulling the previous sections together, the framework follows a repeatable workflow that takes an organization from initial asset discovery through to ongoing monitoring:



1.11 Conclusion

This project set out to design a Cybersecurity Risk Assessment Framework for SMEs, built on the foundations of the NIST Cybersecurity Framework. The resulting model walks organizations through identifying their assets, evaluating relevant threats, calculating risk levels, and selecting appropriate mitigation controls.

Practical testing confirmed that measures such as multi-factor authentication, employee security-awareness training, regular patch management, and reliable backup practices can substantially lower an organization's risk exposure. Because the framework is straightforward to apply and does not demand significant financial or technical resources, it is well suited to SMEs operating with limited cybersecurity budgets and staff.

1.12 References

- [1] NIST Cybersecurity Framework (CSF), Version 2.0
- [2] CERT-In Security Guidelines and Advisories
- [3] Digital Personal Data Protection (DPDP) Act, 2023
- [4] OWASP Top 10 Web Application Security Risks
- [5] Microsoft Security Documentation
- [6] CIS Critical Security Controls, Version 8